QRShield: Explainable Multimodal Quishing Detection

Comprehensive Viva Examination & Defense Handbook | Fall 2026

Course & Institution	CSET485 — AI and Society | SCSET, Bennett University, Greater Noida
Candidate / Lead	Harshit Pahuja (Roll No: s24cseu0736) — Lead & System Architect
Team Identification	Team ID: 54 (Hemang Nag, Saatvik Sharma, Tanish, Rohit Upadhyay, Bharat Kumar)
Core Architecture	Zero-Contact Static Analysis, 29-Feature Random Forest, MobileNetV2 CNN, Isotonic Calibration

1. Executive 90-Second Opening Pitch (Verbal Script)

■ Verbal Delivery Script (Memorize for Viva Opening)

"Good morning/afternoon, respected examiners.
Our project is QRShield: Explainable Multimodal Quishing Detection with Zero-Contact Static Analysis developed for CSET485 (AI and Society).

Quishing (QR code phishing) is rapidly expanding because human vision cannot decipher 2D barcodes. Attackers exploit this opacity to bypass corporate email gateways and deceive mobile citizens with physical sticker overlays.

Traditional detectors either blindly open destinations or perform hazardous dynamic crawling. QRShield eliminates these risks via a strict Zero-Contact architecture: we decode barcodes purely in memory with OpenCV without making any live network pings or DNS lookups.

Our system fuses two complementary static modalities:

1. *A 29-feature lexical Random Forest model analyzing URL character distributions and Shannon entropy.*
2. *A fine-tuned MobileNetV2 CNN examining the physical barcode matrix for visual and density anomalies.*

By combining both branches using soft voting (55% URL / 45% Image) and calibrating probabilities with Isotonic Regression, QRShield achieves 98.77% accuracy and slashes false alarms by 86.2% on 70,000 domain-grouped benchmark samples from CIC-Trap4Phish, running in just 5.91 milliseconds on CPU with complete TreeSHAP and Grad-CAM explainability."

2. AI & Society: Ethical, Societal & Governance Framework

In direct alignment with CSET485 (AI and Society), QRShield embeds core ethical and legal principles directly into its system architecture:

Ethical Pillar	Societal & Security Rationale	QRShield Technical Implementation

Harm Prevention (Zero-Contact)	Dynamic web crawlers risk triggering drive-by malware exploits or notifying attackers via tracking tokens (?victim=123).	Inert memory-only string handling. Strictly 0 network requests, 0 DNS lookups, and 0 headless browser rendering.
Privacy by Design (Anti-Surveillance)	Cloud-based scanners create telemetry logs of everywhere a citizen travels and every transaction they attempt.	100% on-device local execution. Zero telemetry leaves the device, complying with India's DPDPA 2023 & GDPR.
Human Agency & Transparency	Opaque black-box blocks ('Access Denied') cause alarm fatigue and strip users of decision autonomy.	Cognitive Co-Pilot approach: Calibrated risk scores (Low/Mod/High/Crit) backed by TreeSHAP & Grad-CAM justifications.
Sustainable & Green AI	Heavy vision-language models hosted on GPU server farms produce massive operational carbon footprints.	Compact MobileNetV2 (3.4M parameters) + Random Forest operates in 5.91 ms on commodity CPUs with negligible energy.

3. Multimodal System Architecture & Operational Flow

The QRShield processing pipeline operates across six distinct, deterministic stages:

• **Stage 1: Zero-Contact Ingestion & Matrix Extraction:** The uploaded QR image is ingested into memory as an uncompressed RGB matrix. OpenCV's cv2.QRCodeDetector identifies timing/finder patterns and decodes the embedded string into an inert buffer.

• **Stage 2: Lexical URL Feature Extraction (29 Dimensions):** The inert string buffer is analyzed across 29 static lexical indicators including structural lengths, character ratios, subdomain hierarchies, query parameter counts, protocol flags, and Shannon character entropies.

• **Stage 3: Deep Vision Feature Extraction (MobileNetV2):** In parallel, the raw QR image matrix is resized to 224x224x3, normalized via ImageNet distributions, and passed through an inverted-residual MobileNetV2 convolutional backbone to extract spatial and density representations.

• **Stage 4: Prediction-Level Soft Voting Fusion:** The independent class posterior estimates P_url and P_img are combined via optimal validation weights: P_raw = 0.55 * P_url + 0.45 * P_img.

• **Stage 5: Non-Parametric Isotonic Calibration:** The raw probability is transformed via a fitted Isotonic Regression step function to align nominal model confidence with empirical Bayesian event likelihood, evaluated against threshold tau* = 0.5434.

• **Stage 6: Dual Explainability Generation:** TreeSHAP decomposes the URL prediction into additive feature contributions, while Grad-CAM projects gradient activations onto the final convolutional feature map (features[18]) to generate a spatial thermal saliency map.

4. Technical Deep Dive: The Dual Branches

4.1 Static Lexical URL Feature Extraction (29 Features)

Phishing URLs exhibit structural and statistical anomalies compared to legitimate web destinations. QRShield categorizes 29 static features across six distinct mathematical groups:

Feature Category	Specific Variables	Security & Fraud Indication
Structural Lengths (d=4)	url_length, hostname_length, path_length, query_length	Phishing URLs are extended to obfuscate targets or embed redirect parameters.
Delimiters (d=8)	num_dots, num_subdomains, num_hyphens, num_underscores, num_slashes, num_at, num_percent, num_colon	@ abuses browser basic auth; excessive hyphens spoof brands (e.g. secure-login-paypal.com).
Character Ratios (d=4)	digit_count, digit_ratio, alpha_ratio, special_ratio	Machine-generated obfuscation exhibits elevated hex and numeric frequencies.
Query Structure (d=4)	num_question, num_equals, num_ampersand, query_param_count	Quantifies parameter stuffing utilized in credential-stealer phishing kits.
Protocol & Host Flags (d=6)	has_https, has_ip_hostname, has_port, hostname_hyphen_count, suspicious_token_count	Raw IPv4 hostnames (http://192.168.1.1/login) and missing TLS indicate severe malicious risk.
Shannon Entropies (d=3)	url_entropy, hostname_entropy, path_entropy	Measures information disorder: H = -sum(p_i * log2(p_i)). High entropy indicates algorithmic domain generation (DGA).

4.2 Deep Vision Modeling (MobileNetV2 CNN Architecture)

While lexical features inspect destination syntax, the visual QR grid captures optical properties that text analysis misses entirely:

• High Version Density: Malicious QR codes frequently encode large URLs or obfuscated payloads, producing dense, fine-grained module grids.

• Visual Artifacts & Tampering: Physical sticker overlays create misalignment along finder patterns and edge contrast variations.

• MobileNetV2 Backbone: Uses inverted residual blocks with depthwise separable convolutions (3.4M parameters), drastically reducing FLOPs compared to ResNet-50.

• Two-Stage Transfer Learning:

- Stage A: Feature extractor frozen; custom linear head trained with AdamW (lr = 1e-3, weight decay = 1e-4) for 2 epochs.

- Stage B: Top residual blocks (blocks 14–18) unfrozen and fine-tuned at lr = 1e-4 for 2 epochs.

5. Multimodal Fusion & Isotonic Calibration Mathematics

> **■ Mathematical Formulations**
>
> *1. Prediction-Level Soft Voting Fusion:*
>
> *P_raw = w_url * P_url + w_img * P_img*

> *Validation Grid Search: w_url = 0.55, w_img = 0.45 (Yielded maximum validation F1 = 0.9956)*
>
> *2. Isotonic Probability Calibration (PAVA Algorithm):*
> *min_g sum_{i=1}^N (y_i - g(P_raw,i))^2 subject to g(p_a) <= g(p_b) for all p_a <= p_b*
> *Calibrated Probability: P_cal = g_iso(P_raw)*
>
> *3. Decision Rule & Optimal Threshold:*
> *y_hat = 1 (MALICIOUS) if P_cal >= 0.5434, else 0 (BENIGN)*
>
> *4. Probabilistic Error (Brier Score):*
> *Brier Score = (1/N) * sum_{i=1}^N (P_i - y_i)^2*
> *Raw Fusion Brier: 0.02659 --> Calibrated Brier: 0.01022 (61.5% Error Reduction)*

6. Dual Explainable AI (XAI) Framework

To eliminate black-box distrust, QRShield delivers dual-modality explanations:
1. TreeSHAP (Lexical Attribution): Based on cooperative game theory, computes exact additive feature attributions phi_i such that sum(phi_i) = f(x) - E[f(X)].
  Top 5 Predictive Signals Identified:
  - path_entropy (mean |phi| = 0.0714)
  - path_length (mean |phi| = 0.0624)
  - num_subdomains (mean |phi| = 0.0515)
  - num_hyphens (mean |phi| = 0.0512)
  - hostname_entropy (mean |phi| = 0.0394)
2. Grad-CAM (Spatial Visual Saliency): Computes gradients at MobileNetV2's final convolutional layer (features[18]) and calculates thermal activation overlays:
  alpha_k^c = (1/Z) * sum_i sum_j (d y^c / d A_{i,j}^k), L_{Grad-CAM}^c = ReLU(sum_k alpha_k^c * A^k)

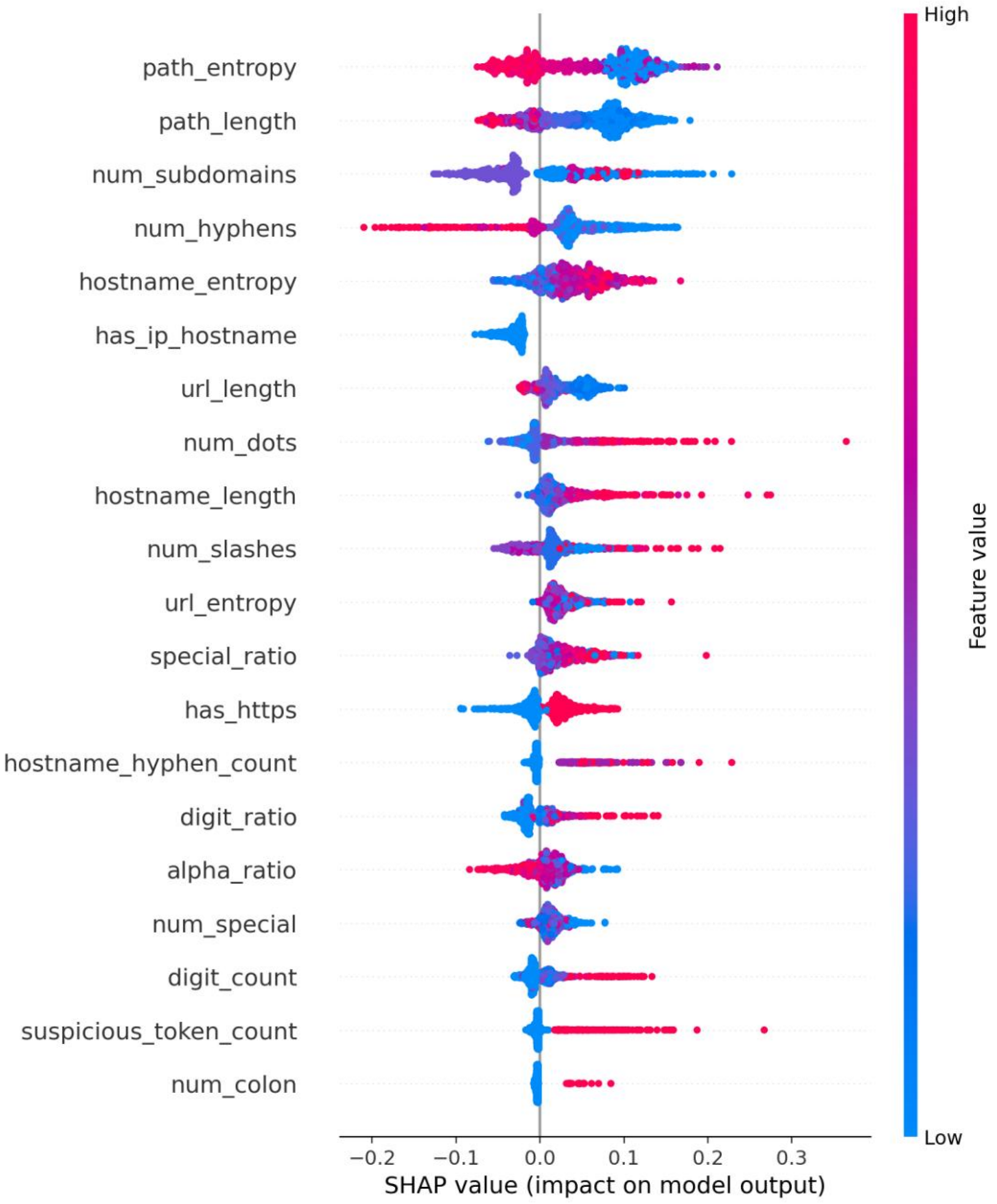


Figure 1: TreeSHAP Global Feature Importance Summary across 1,000 Test Background Instances.



Figure 2: Grad-CAM Thermal Activation Heatmap Highlighting Suspicious 2D Barcode Modules.

7. Dataset Engineering & Leakage-Free Splitting

• Source Dataset: CIC-Trap4Phish (Canadian Institute for Cybersecurity, 2025).
• Data Hygiene Pipeline: Filtered 2.15 million raw records down to 387,015 clean canonical pairs, resolving 10,305 contradictory duplicate labels.
• Benchmark Evaluation Corpus (70,000 samples):
  - Training Set: 50,000 samples (2,291 benign, 47,709 malicious)
  - Validation Set: 10,000 samples (1,009 benign, 8,991 malicious)
  - Test Set: 10,000 samples (1,605 benign, 8,395 malicious)

• Strict Registrable Domain Grouping (eTLD+1):
  In conventional random splits, URLs from the same domain (e.g. fake-bank.com/login and fake-bank.com/verify) leak across train and test sets, causing the model to memorize domain names rather than learning generalized structural features.
  QRShield enforces strict domain-level partitioning using Mozilla's Public Suffix List (tldextract), guaranteeing:
  --> Exactly 0 Shared Domains, 0 Shared URLs, and 0 Shared Image Hashes across splits.

8. Empirical Results & Benchmark Performance

Model Architecture	Accuracy	Precision	Recall	F1-Score	ROC-AUC	FPR	CPU Latency
URL Branch (Random Forest)	92.67%	92.71%	99.06%	95.78%	94.80%	40.75% (654/1605)	0.81 ms
Image Branch (MobileNetV2)	96.45%	96.62%	99.24%	97.91%	99.28%	18.13% (291/1605)	5.10 ms

QRShield Multimodal Fusion	**98.77%**	**98.94%**	**99.61%**	**99.27%**	**99.67%**	**5.61% (90/1605)**	**5.91 ms**

Key Numerical Takeaway for Viva: Multimodal fusion reduced false alarms from 654 (URL model) down to 90—an 86.2% reduction in false positives—while simultaneously lifting recall to 99.61% and total accuracy to 98.77% in under 6 milliseconds.

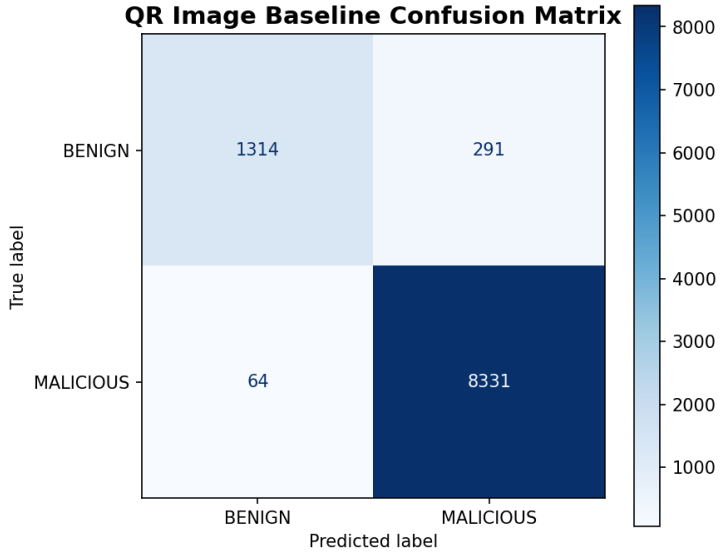


Figure 3: Confusion Matrix Benchmark on Held-out 10,000 Test Partition.

9. Harshit Pahuja's Personal Contribution Defense

When the examination committee inquires regarding individual technical ownership:

• System Architecture & Pipeline Design: Engineered the end-to-end dataflow linking OpenCV in-memory barcode decoding, parallel dual-branch inference, fusion math, and frontend API delivery.

• Multimodal Soft Voting Formulation: Designed and conducted grid search optimization yielding the optimal 55% URL / 45% Image weighting.

• Isotonic Probability Calibration: Implemented the PAVA non-parametric calibrator, reducing the Brier error score by 61.5% and establishing the tuned decision threshold tau* = 0.5434.

• Production FastAPI Microservice: Built the async backend engine (backend/main.py) with structured Pydantic schemas, health checks, memory-cached model deserialization, and CORS security.

• Verification & Quality Assurance: Authored the 10-suite automated integration test harness (tests/test_prototype.py), ensuring 100% test pass rate across all edge cases.

10. Top 15 Tough Viva Questions & Bulletproof Model Answers

Q1: Why did you choose a multimodal approach instead of relying purely on URL lexical features?

Answer: Sir, lexical features inspect URL syntax but suffer a high 40.75% false positive rate because modern marketing URLs contain long query tokens and high entropy. The vision model inspects the physical 2D barcode matrix. By combining both signals, false alarms dropped from 654 to 90 (an 86.2% reduction) and accuracy rose to 98.77%.

Q2: What is the Zero-Contact Security Policy and why is it critical?

Answer: Traditional scanners crawl links with headless browsers. This exposes devices to drive-by browser RCE, triggers attacker tracking beacons (?victim=123) validating victim phone/email targets, and gets bypassed by cloaking filters. QRShield decodes barcodes strictly as inert string buffers in memory—zero socket connections, zero DNS pings, zero HTTP requests.

Q3: How did you prevent data leakage during dataset partitioning?

Answer: If URLs are partitioned randomly, multiple URLs from the same malicious domain (e.g. evil-portal.com/login and evil-portal.com/verify) end up in both training and test sets. The model simply memorizes the domain name. We enforced Strict Registrable Domain Grouping (eTLD+1) using Mozilla's Public Suffix List (tldextract), ensuring zero domain, URL, or image hash overlap across splits.

Q4: Why MobileNetV2 rather than ResNet-50 or Vision Transformers (ViT)?

Answer: MobileNetV2 uses inverted residual blocks and depthwise separable convolutions, keeping parameters down to 3.4M. ResNet-50 requires ~25M parameters and ViT requires ~86M, which are impractical for low-latency edge mobile processing. MobileNetV2 achieves 96.45% accuracy while inferencing in just 5.1 ms on a standard CPU.

Q5: Why did you apply Isotonic Regression instead of Platt Scaling?

Answer: Platt scaling assumes a parametric sigmoid relationship, which underfits when confidence distortions are non-monotonic or multi-modal. Isotonic Regression is non-parametric; it fits a piecewise monotonic step function via the Pool Adjacent Violators Algorithm (PAVA). It reduced our Brier calibration score by 61.5% (0.0266 to 0.0102).

Q6: What is a Brier Score and why does it matter in quishing detection?

Answer: The Brier score measures the mean squared difference between predicted probabilities and actual binary outcomes: (1/N)*sum(P_i - y_i)^2. In security applications, an uncalibrated 90% confidence score might only correspond to a 60% real threat probability. Calibrated Brier score of 0.0102 ensures assigned risk tiers reflect real-world threat frequencies.

Q7: Explain the mathematical intuition of Shannon Entropy in your URL branch.

Answer: Shannon entropy H(T) = -sum(p_i * log2(p_i)) quantifies character randomness. Natural English words (e.g. /account/login) have low entropy (~2.5-3.5 bits/char). Algorithmic domain generation (DGAs) or token stuffing (e.g. /x89q2l_k9) have high entropy (>4.5 bits/char). Path and hostname entropy were identified by TreeSHAP as top-tier predictive signals.

Q8: How does TreeSHAP provide local explainability?

Answer: TreeSHAP calculates exact Shapley additive explanations from cooperative game theory: f(x) = phi_0 + sum(phi_i). It computes the marginal contribution of each feature across all possible decision tree feature permutations in polynomial time O(TLD^2), showing the user exactly which lexical anomalies (e.g. 4 deceptive hyphens) triggered the threat score.

Q9: How does Grad-CAM work on a QR barcode image?

Answer: Grad-CAM computes the partial derivatives of the malicious class score y^c with respect to feature maps A^k in the final convolutional layer (features[18]). These gradients are global-average-pooled into importance weights alpha_k^c and combined via ReLU to highlight the physical barcode modules (finder patterns, timing lines, dense payload matrix) that the CNN focused on.

Q10: Why is the decision threshold set to 0.5434 instead of the default 0.5000?

Answer: The default 0.5 threshold assumes symmetric misclassification costs and perfectly balanced data. Because quishing datasets feature natural class imbalance, we tuned the threshold on the validation split specifically to optimize the F1-score, settling on tau* = 0.5434 to achieve an optimal balance between precision (0.9894) and recall (0.9961).

Q11: What are the failure modes of QRShield (False Positives & False Negatives)?

Answer: False Positives (90 samples): Benign marketing URLs featuring affiliate tracking strings and multi-tier hyphenated subdomains. False Negatives (33 samples): Newly registered, ultra-short clean domains that mimic normal landing pages before server-side redirect activation occurs.

Q12: How does QRShield align with India's DPDPA 2023 and GDPR?

Answer: Under GDPR and DPDPA Section 6, harvesting user URLs and camera feeds creates unlawful digital tracking footprints. QRShield processes all images and URLs locally on the user's client hardware. No scanned URLs, camera streams, or telemetry logs are ever transmitted to cloud servers.

Q13: Why did you freeze the MobileNetV2 backbone in Stage A of transfer learning?

Answer: If random classification head weights are backpropagated into a pre-trained backbone with a large learning rate, large initial gradient updates destroy the pre-trained ImageNet feature representations (catastrophic forgetting). Freezing the backbone stabilizes the head before unfreezing top layers (blocks 14–18) for delicate fine-tuning.

Q14: How does your frontend UI prevent warning fatigue?

Answer: Rather than showing generic 'Warning: Malicious Link' popups that users reflexively dismiss, QRShield uses cognitive co-pilot principles: clear color-coded risk tiers (Low/Mod/High/Crit), interactive TreeSHAP attribution badges explaining why it is risky, and a Grad-CAM visualizer with an inert copyable link destination.

Q15: What are the planned Phase 2 extensions for QRShield?

Answer: 1. Edge Mobile Port: INT8 quantization and ONNX Runtime deployment for native Android/iOS camera integration. 2. Adversarial Defense: Hardening against printed barcode tearing and adversarial sticker patches. 3. Offline Bloom Filter: Local caching of 1M+ known malicious domain hashes for sub-millisecond instant lookup without network connectivity.

11. Prototype Verification & Live Demo Commands

> **■ Live Demo Runbook**
> *1. Start FastAPI Backend Engine:*
> *cd "c:\Users\Harshit Pahuja\Desktop\New folder\QRShield"*
> *.\.venv313\Scripts\python.exe -m uvicorn backend.main:app --host 127.0.0.1 --port 8000*
> *--> Accessible at http://127.0.0.1:8000 (Swagger docs at /docs, health probe at /health)*
>
> *2. Start React 18 Frontend Dashboard:*
> *cd frontend*
> *npm run dev -- --host*
> *--> Accessible at http://localhost:5173*
>
> *3. Run Automated Integration Test Suite (100% Pass Rate):*
> *pytest tests/*
> *--> Executes 10 unit and integration tests verifying OpenCV decode, 29-feature consistency, model deserialization, soft-voting math, and calibration.*